Data Privacy Impact Assessment (DPIA) — Anti-Fraud & Trust Integrity (identity clustering · fraud detection · enforcement)

> **DRAFT — for DPO (Indalecio Sacdalan Casasola II) + PH counsel finalization; not yet adopted.** · 2026-07-07

> Prepared under RA 10173 (Data Privacy Act of 2012), its IRR, and NPC guidance on Privacy Impact Assessments (NPC Advisory No. 2017-03 and related issuances). This is the standalone, full DPIA for register row **R-08** (`05_DPIA_Register_DRAFT_2026-07-05.md`). It is **HIGH-risk** because it (a) **repurposes** already-collected personal data (device fingerprint, normalized home address, payment-sender identity) for a **new purpose** without the data subject's active choice, and (b) performs **automated decision-making with significant effects** — it can automatically hide a vendor's livelihood-bearing listing and, on human confirmation, permanently ban it.

> ## ■ STATUS — this processing is LIVE IN PRODUCTION as of 2026-07-07, ahead of counsel sign-off (read first)

> The anti-fraud stack (repo PRs #2834/#2835/#2836/#2838/#2841 · migrations `20270516600000`, `20270517644717`, `20270518682623`) was **shipped to production on 2026-07-07**. The engineering PRs each flagged **counsel review PENDING** for this RA 10173 processing; the **owner (PIC) elected to ship ahead of that review** to unblock the feature. **This DPIA is therefore a retroactive assessment** — it documents processing that is already occurring and identifies what must still be done (chiefly the **transparency/disclosure gap in §6**) to bring it fully into compliance. **Counsel review remains outstanding and is the gating adoption item.** Nothing in this DPIA should be read as confirming the processing was cleared before launch.

0. Instrument identity

Field	Value
Personal Information Controller (PIC)	SETNAYAN SOFTWARE DEVELOPMENT SERVICE — sole proprietorship of Indalecio Sacdalan Casasola II · DTI Business Name Reg. No. 8297508. Operating brand: Setnayan.
Data Protection Officer (DPO)	Indalecio Sacdalan Casasola II · iscasasolaii@gmail.com · registered (or registration in progress `[TO CONFIRM]`) with the NPC
DPIA owner	DPO (Indalecio Sacdalan Casasola II)
Processing assessed	Anti-Fraud & Trust Integrity — identity clustering + vendor fraud detection/scoring + two-stage enforcement — register R-08
Governing policy	`01_Contracts/Setnayan_Privacy_and_Security_Policy.md` § 1.1 (identity/device/payment data collected), § 2 (purposes), § 3 (storage/RLS), § 4 (retention), § 10 (sub-processors/cross-border) — **an Anti-Fraud amendment is REQUIRED and not yet drafted (see §6)**

Feature specs	`03_Strategy/Anti_Fraud_Trust_Integrity_2026-07-05.md` §§ 3–6
Shipped code	migrations `20270516600000_identity_clusters_phase2`, `20270517644717_fraud_signals_detection_engine`, `20270518682623_fraud_enforcement_state_and_audit`; `apps/web/lib/fraud-detection*.ts`; admin surface `/admin/fraud`
Risk level (inherent)	**HIGH** — repurposed personal data + involuntary profiling + automated decisions with significant effects
DPIA status	DRAFT — pending DPO adoption + PH counsel review; **processing is already live** (see status banner)
Version / date	2026-07-07

---

1. Description of the processing

1.1 What the processing is

Three layered, service-internal mechanisms that protect marketplace trust signals (reviews, booking counts, badges) from manipulation:

1. **Identity clustering** — links multiple user accounts that are probably the *same person or household* by **shared strong signals**: the same **device fingerprint**, the same **normalized home address**, or the same **payment-sender identity**. Each connected group is assigned an opaque `cluster_id`.
2. **Trust-stat de-duplication** — vendor review counts, ratings, and completed-booking counts are counted **per cluster, not per account**, and **arm's-length-excluded** (a review/booking from someone in the vendor owner's or team's own cluster does not count). This is what makes fake-account rings ineffective.
3. **Fraud detection + two-stage enforcement** — per-vendor anomaly **signals** (score 0–100) are computed and stored; a high aggregate score can **auto-suspend** a vendor (reversible), and — only on a second admin's confirmation via the four-eyes gate — a vendor can be **wiped + permanently banned** (irreversible).

1.2 Why it is processed (purpose)

Fraud prevention and marketplace integrity — to stop vendors from inflating their reviews, ratings, badges, and booking counts with sockpuppet accounts (fake couples on shared devices/addresses/payment sources), and to detect and act on anomalous trust-manipulation patterns. The purpose protects **couples** (who rely on honest trust signals to choose vendors) and **honest vendors** (who are otherwise out-competed by fabricated reputations).

1.3 Lawful basis (preliminary — to be confirmed by counsel)

Legitimate interest — RA 10173 § 12(f): fraud prevention is a recognized legitimate interest of the PIC and of honest data subjects. This basis requires a documented **legitimate-interest balancing** (necessity ↔ data-subject impact) and **transparency** (the processing must be disclosed). **Neither the balancing test nor the disclosure yet exists — this is the headline finding (§6).** `[TO CONFIRM]` — DPO/counsel to confirm § 12(f) as the basis for each data category and the automated-decision provisions of § 16(c) / § 34.

1.4 A secondary use of already-collected data — NO new collection

Critically, this processing **collects no new personal data.** It **repurposes** data already collected and recorded for other purposes:

- **Device fingerprint** — `user_devices.device_hash` (already collected for session/security).
- **Normalized home address** — `users.address_normalized` (already collected at account/profile).
- **Payment-sender identity** — `payments.reference_number` joined to the paying user (already collected for apply-then-pay reconciliation, DPS-08).

Because it is a **new purpose over old data**, the compliance question is one of **purpose-compatibility + disclosure**, not new consent for collection. Under RA 10173 a further, compatible processing purpose is permissible on a lawful basis, **but it must be disclosed** — which it currently is not (§6).

1.5 Data subjects

- **Couples / customers / guests** — whose device/address/payment signals are clustered to detect review/booking rings. **They never see cluster membership** (service-role only). This is the more novel, involuntary population.
- **Vendors** — whose trust stats are de-duplicated and who are **scored, and potentially auto-suspended or banned**. This is the population subject to **automated decisions with significant effects**.

1.6 Data categories processed

- **Identity-link signals (input):** device fingerprint hash, normalized home address, payment-sender reference. (Personal information; **not** SPI under § 3(l).)
- **Derived — identity cluster membership:** an **inference** that two or more accounts are the same person/household. (A new derived personal datum about the linked individuals.)
- **Derived — vendor fraud signals/scores:** per-vendor anomaly signals (`ring`, `velocity`, `graph_isolation`, `import_spike`, `rating_shape`), each with a 0–100 score and a **non-PII** `evidence` JSONB (counts, ratios, opaque cluster labels, booleans — **no names, no addresses, no raw identifiers**).
- **Enforcement state:** `fraud_suspended_at` / `fraud_banned_at` / `fraud_tombstoned` on the vendor; `voided_by_fraud` flags on the vendor's reviews/events; an append-only `fraud_enforcement_audit` row per action.
- **Intentionally NOT processed: IP address** — no core identity table captures an IP, and IP-capture infrastructure was **deliberately not built** (deferred to a future "Phase 2.1"). This is a data-minimization choice.

1.7 Systems, storage, and retention

- **Database of record:** Supabase Postgres (**Singapore**). `identity_clusters` + `user_identity_signals` (views/matviews), `fraud_signals` + `vendor_fraud_scores`, enforcement columns + `fraud_enforcement_audit`.
- **Access control: service-role / admin ONLY.** Every object carries `REVOKE ALL FROM anon, authenticated` and/or `is_admin()` RLS at `CREATE TABLE` time — **couples and vendors can never read cluster membership, fraud signals, or scores.**
- **Cross-border:** SG (Supabase) only for this processing. No US/third-party AI sub-processor is involved (the clustering + scoring are plain SQL/TypeScript in-house).
- **Retention:** `identity_clusters` / `vendor_fraud_scores` are **recomputed matviews** (no independent history). `fraud_signals` + `fraud_enforcement_audit` **persist — a specific retention rule for these is not yet defined `[TO CONFIRM]`** (see AF-8). Underlying signal inputs follow their source systems' retention (device/address = account retention; payment = 5-year tax retention, DPS-08).

2. Necessity & proportionality assessment

2.1 Is the processing *necessary* for the purpose?

Marketplace trust is the product's core promise; fabricated reviews/bookings directly harm couples and honest vendors. **Non-identity-based** anti-fraud (e.g. manual moderation) does not scale and cannot see cross-account rings. Identity clustering is the mechanism that actually neutralizes sockpuppet rings, and per-cluster de-duplication is the minimal way to make fake accounts ineffective without deleting anyone. So the clustering + de-duplication layer is **necessary and well-targeted**.

Automated **scoring** is necessary to triage at scale; automated **suspension** is a proportionality choice (see §2.2) — justified only because it is **reversible** and set at a **high-confidence threshold**.

2.2 Proportionality — is it minimized, and are the effects proportionate?

The design minimizes structurally:

- **No new data collected** — secondary use of existing signals only (§1.4).
- **IP deliberately excluded** — the most privacy-invasive identity signal was not built (§1.6).
- **Service-role-only** — the inferences are never exposed to any data subject or other user; they exist solely to correct trust math and feed the admin queue.
- **Non-PII evidence** — the stored fraud evidence carries counts/ratios/opaque labels, not identities.
- **The irreversible action is NOT automated** — only the **reversible** auto-suspend is automated, and only at a **high aggregate score (≥ 90)**, strictly above the advisory band. The **wipe + permanent ban** requires a **second admin's confirmation** through the existing four-eyes gate — a human, accountable, logged decision, never the machine's.
- **Appeal path** — an enforcement action opens a help-center appeal ticket stub, giving the vendor a route to contest.

Conclusion. The processing can be proportionate **conditional on §6** — i.e. once (a) it is **disclosed** to data subjects and (b) a **legitimate-interest balancing** is documented and counsel-reviewed. The automated-suspension effect is proportionate **because** it is reversible and human-reversible in one action; the irreversible effect is proportionate **because** it is never automated.

---

3. Consultation

- **DPO:** prepared for DPO review and sign-off (Indalecio Sacdalan Casasola II). The transparency finding (§6), the lawful-basis mapping (§1.3), the retention gap (AF-8), and the automated-decision rights (§6 / AF-5) are referred to the DPO and PH counsel.
- **Data subjects: not yet consulted or notified** for this specific processing — there is currently **no notice** that device/address/payment data is used to cluster identities for fraud prevention, and no notice to vendors that they may be automatically scored/suspended. Closing that is the §6 recommendation.
- **External counsel / NPC: required** — register R-08 is counsel-first, and the processing shipped ahead of that review (status banner). Counsel to confirm the § 12(f) basis, the § 16(c)/§ 34 automated-decision provisions, the retention rule, and whether an NPC consultation is advisable given the automated-enforcement effect.

---

4. Risk assessment table

Inherent risk = likelihood × impact **before** controls. Residual risk = risk remaining **after** the controls already built (§5).

#	Risk	Likelihood	Impact	Inherent	Controls already built	Residual
AF-1	**Undisclosed repurposing** — device/address/payment data collected for other purposes is used to cluster identities for fraud prevention **without notice** to the data subject (transparency failure under § 12(f) + the § 16 right to be informed)	High	High	**High**	Service-role-only (never surfaced); no new collection; purpose-limited to fraud prevention	**Med–High — NOT resolved by current controls.** Reduces to Low only after the Privacy Policy discloses the processing + the right to object (§6). **Headline gap.**
AF-2	**Wrongful automated suspension** of a legitimate vendor (false positive hides their livelihood-bearing listing)	Med	High	**High**	**Reversible** auto-suspend; high threshold (score ≥ 90, above the advisory 60); admin Dismiss / Un-suspend in one action; fail-soft scoring	**Low–Med**
AF-3	**Wrongful irreversible ban** — a vendor is wiped/banned and reviews/events voided in error	Low	High	**High**	**Never automated** — routed through the **two-admin (four-eyes) gate**; typed business-name confirmation; append-only `fraud_enforcement_audit`; help-center appeal ticket opened	**Low–Med**

AF-4	**Cluster mis-linkage** — unrelated people linked as one identity (shared family PC, shared address, one person paying for another) → a false "same identity" inference	Med	Med	**Med**	Used only to **de-dup trust stats** + as one fraud-signal input, **never surfaced** to users; enforcement needs corroborating anomaly signals, not cluster membership alone; bounded (≤ 64-hop) cycle-guarded closure	**Low–Med**
AF-5	**Data-subject rights over automated processing** — a vendor cannot access/understand/contest an automated decision (RA 10173 § 16(c) right to object; § 34 rights re automated processing)	Med	High	**Med–High**	Appeal-ticket stub on enforcement; irreversible step is human-decided; audit trail records rationale	**Med** — a **formal** access/object/contest path for automated scoring is not yet documented (see §6)
AF-6	**Breach of the identity-cluster / fraud store** — exfiltration of who-is-linked-to-whom or who-is-flagged	Low	Med–High	**Med**	**Service-role/admin ONLY** (`REVOKE ALL FROM anon, authenticated`, `is_admin()` RLS at CREATE); non-PII `evidence`; SG-only (no third-party processor); AES-256; TLS 1.3	**Low**
AF-7	**Function creep** — cluster/fraud data reused for marketing, ranking, or sold/shared	Low	High	**Med**	Purpose-limited by design + policy § 2.3 (no sale/cross-vendor sharing/advertising); service-role-only	**Low** — pending an explicit policy lock naming this processing

AF-8	**Over-retention of fraud signals** — `fraud_signals` / `fraud_enforcement_audit` kept longer than necessary	Med	Med	**Med**	Matviews (`identity_clusters`, `vendor_fraud_scores`) recomputed, no history; enforcement audit is intentionally durable	**Med** — no explicit retention/aging rule for `fraud_signals` yet `[TO CONFIRM]` (audit trail retention should be justified against BIR/dispute needs)

---

5. Controls already built

Load-bearing for the residual ratings above; all verified against the shipped migrations/code:

- **Service-role / admin ONLY** — `identity_clusters`, `user_identity_signals`, `fraud_signals`, `vendor_fraud_scores`, and the enforcement/audit objects carry `REVOKE ALL FROM anon, authenticated` and/or `is_admin()` RLS **at `CREATE` time**. No data subject can read them.
- **No new data collection** — secondary use of `user_devices.device_hash`, `users.address_normalized`, `payments.reference_number` only.
- **IP deliberately not captured** — the most invasive identity signal was left unbuilt (data minimization).
- **Non-PII evidence** — `fraud_signals.evidence` holds counts/ratios/opaque cluster labels/booleans, not identities.
- **Automated action is the *reversible* one only** — auto-suspend at aggregate score ≥ 90 (above the advisory 60); it hides the listing + freezes badges but **destroys nothing** and reverses in one admin action.
- **Irreversible action is human + four-eyes** — wipe + permanent ban routes through the existing **two-admin approval gate** (`admin_approval_requests`, new `approve_fraud_wipe_ban` action type); a *different* admin confirms; never automated.
- **Append-only audit** — every enforcement action writes a `fraud_enforcement_audit` row (actor, rationale, evidence snapshot).
- **Appeal route** — enforcement opens a help-center appeal ticket stub.
- **Defense-in-depth freeze** — a fraud-frozen vendor is excluded from the marketplace query, `/v/[slug]`, `api/v1/vendors`, and the Spotlight-Award candidate pool.
- **Bounded computation** — the cluster closure is a cycle-guarded, ≤ 64-hop recursive CTE (to be promoted to a nightly union-find job at scale).

---

6. KEY FINDING — the transparency & automated-decision gap (headline)

Finding. The processing is lawful in principle on a **legitimate-interest (§ 12(f))** basis, but two accountability requirements of that basis are **not yet met**, and the processing is **already live** (status banner):

1. **No disclosure / notice.** Neither couples nor vendors are told that (a) their **device fingerprint, home address, and payment-sender identity** are used to **cluster identities for fraud prevention**, nor that (b) vendors may be **automatically scored and suspended**. RA 10173's § 16 right-to-be-informed and the transparency limb of § 12(f) require this to be disclosed. **This is the single most important gap.**

2. **No documented legitimate-interest balancing (LIA)** and **no formal automated-decision rights path.** § 12(f) requires the PIC's interest to be weighed against data-subject rights and freedoms, recorded. And because auto-suspension is a decision producing a **significant effect** on a vendor, the § 16(c) right to object and § 34 provisions on automated processing should be reflected in a documented **contest/appeal** path (the ticket stub exists; the formal process does not).

Recommendation (the headline recommendation of this DPIA).

- **MUST — publish an Anti-Fraud disclosure** in the Privacy Policy (a new amendment, mirroring the Person-Graph amendment pattern): state plainly that device/address/payment data may be used to detect and prevent fraudulent trust manipulation, that vendors may be subject to automated integrity checks and (reversible) suspension with a human-reviewed, appealable path to any permanent action, and the legitimate-interest basis + how to object. Present it to couples and vendors.
- **MUST — record a legitimate-interest balancing test (LIA)** for the clustering + scoring, and a **formal vendor contest/appeal procedure** for automated suspensions (elevate the ticket stub to a documented § 16(c)/§ 34 path).
- **MUST — obtain the outstanding counsel review** (register R-08 is counsel-first; the processing shipped ahead of it — status banner). Counsel to confirm § 12(f) mapping, the automated-decision provisions, and whether an NPC consultation is advisable.
- **SHOULD — define a retention rule** for `fraud_signals` and justify `fraud_enforcement_audit` retention (AF-8).

Until the disclosure (item 1) lands, the residual risk of AF-1 stays **Med–High** and the processing, while operational, is **not fully compliant** on the transparency limb.

---

7. Residual-risk conclusion

With the controls in §5 — above all **service-role-only access**, **no new collection**, **non-PII evidence**, **reversible-only automation at a high threshold**, and the **four-eyes gate on the one irreversible action** — most risks reduce to **Low** (AF-6, AF-7) or **Low–Med** (AF-2, AF-3, AF-4).

However, overall residual risk is CONDITIONAL and cannot be declared Low–Medium until the §6 transparency items land, and the processing is currently **live ahead of counsel review**. Before this can be treated as adopted/cleared:

1. **MUST — publish the Anti-Fraud Privacy Policy disclosure + notice** (AF-1 / §6). *Gating item.*
2. **MUST — record the legitimate-interest balancing (LIA) + a formal automated-decision contest path** (AF-5 / §6).
3. **MUST — complete the outstanding PH counsel review** (R-08 counsel-first).
4. **SHOULD — set a retention rule for `fraud_signals` + justify audit retention** (AF-8).

With items 1–3 done, residual risk across the processing is Low–Medium. Until then it should be treated as **operational-but-not-yet-cleared / counsel-first**, consistent with register R-08. The design itself is sound; the gap is **paperwork + disclosure**, not architecture.

---

8. Sign-off

Role	Name	Signature	Date

Data Protection Officer	Indalecio Sacdalan Casasola II	______	[TO CONFIRM date]
Personal Information Controller	Indalecio Sacdalan Casasola II (for SETNAYAN SOFTWARE DEVELOPMENT SERVICE)	______	[TO CONFIRM date]

Next review date: [TO CONFIRM date] (recommend: on publication of the Anti-Fraud Privacy Policy disclosure, at any material change to the clustering signals / scoring thresholds / enforcement model, or 12 months from adoption, whichever is sooner).

This is a compliant baseline prepared ahead of counsel; it is not a substitute for legal review. To be finalized with Indalecio Sacdalan Casasola II (DPO) and PH counsel. The processing is live in production as of 2026-07-07 ahead of counsel sign-off (owner-elected); the transparency/disclosure upgrade (§6) and the outstanding counsel review are the gating items to bring it fully into compliance.